

Constellation

Constellation - Writeup

Prepared by: CyberJunkie

Machine Author(s): CyberJunkie

Difficulty: Medium

Writeup prepared by: CyberJunkie

Scenario

SOC team was recently made aware of a possible insider threat existence. The suspect employee's workstation was contained and triaged. During memory analysis, Senior DFIR Analyst was able to carve out some interesting urls from the memory. You are provided this evidence to further analyse these and try to find any evidence like evidence of data exfiltration, evidence of contact with malicious entities and so on.

You will be working closely with threat intel team if you find any information regarding the attacking group or individuals involved. You will also be in touch with Forensics team, helping them in timeline creation

Artefacts provided

1- IOCs.txt (txt file), sha1 : D94F86578DED38A794E16D2BACEC124669B2FF99

Skills Learnt

- URL Analysis
- Timeline creation
- Metadata analysis
- OSINT (tracking opsec mistakes)
- Contextual Analysis
- Chaining of multiple Artefacts

Tags

DFIR

Incident Response

Initial Analysis :

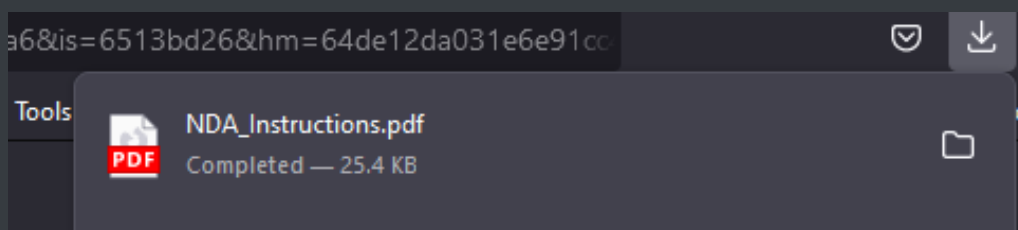
We will start by extracting the provided zip file. We see it contains a single txt file named IOCs.

hackTheBox (H:) > def-content > Constellation > Artifacts			
Name	Date modified	Type	Size
 IOCs	9/27/2023 2:29 PM	Text Document	

Lets open it to see what IOCs are provided.



It looks like we are provided with 2 URLs. The first url looks like a discord attachment link which upon visiting downloads a pdf file named NDA_Instructions.pdf.



Lets open this pdf.

Constellation

Thanks For getting in touch with AntiCorp Gr04p, karen riley. We appreciate you in helping us get our hands on important data for forela. Ita high time we stand against billion dollars corporates who are playing monaply with common folks!! We are attaching instructions on how to get us the data securely.

Follow these in same order.

1. Connect to the server: Using the ssh credentials you were able to find, logon to the server. Run this command : `ssh root@server-IP` . Enter password when prompted
- 2.
3. Once connected to the server, archive the folders containing databases and backups. To create a tar archive of a directory, use the following command:

```
tar -czvf archive.tar.gz /path/to/directory
```

This command will create a compressed tar archive of the folder.

4. After creating the archive, you can use the AWS Command Line Interface (CLI) to transfer the file to the S3 bucket. If you don't have the AWS CLI installed, you can follow the instructions here: <https://aws.amazon.com/cli/>
5. Configure AWS CLI: Once the AWS CLI is installed, you need to configure it with your AWS credentials. Open a terminal and run the following command:

```
aws configure
```

It will prompt you to enter your AWS Access Key ID, Secret Access Key, default region, and default output format. Provide the required information based on your AWS account as provided by our agent to you.

6. With the AWS CLI configured, you can now upload the archive to the S3 bucket. Use the following command:

It looks like some kind of instructions. Upon reading this we find that this pdf was delivered to karen riley whos forela employee. And she is about to perform sabotage and sell sensitive information to a Threat actor group possibly by name of "AntiCorp Gr04p". They are being given instructions on how to collect and exfill data via s3 buckets.

Now lets take a look at second URL. Its a google search url and going to the urls gives us this result

gle how to zip a folder using tar in linux X | 🔍

🔍 All 📺 Videos 📖 Books 🖼️ Images ⋮ More Tools

About 12,000,000 results (0.38 seconds)

Example of using the tar command:

1. 2) Compress directory using the tar command: `tar -czvf dir-compressed.tar.gz test_directory/`
2. 3) Show the archive content: `tar -tf archive.tar.gz.`
3. 4) Add content to the existing archive: `tar -rvf existing-archive-name.tar file-directory-to-compress/`
4. 5) Update content in an archive:

More items... • 29-Jun-2021

 **GeeksforGeeks**
<https://www.geeksforgeeks.org/how-to-compress-and-e...>

How to Compress and Extract Files Using ... - GeeksforGeeks

🔍 About featured snippets • 🗨️ Feedback

People also ask ⋮

How do I zip a folder using tar? ▼

How do I tar a folder in Linux? ▼

Feedback

 **How-To Geek**
<https://www.howtogeek.com/Linux>

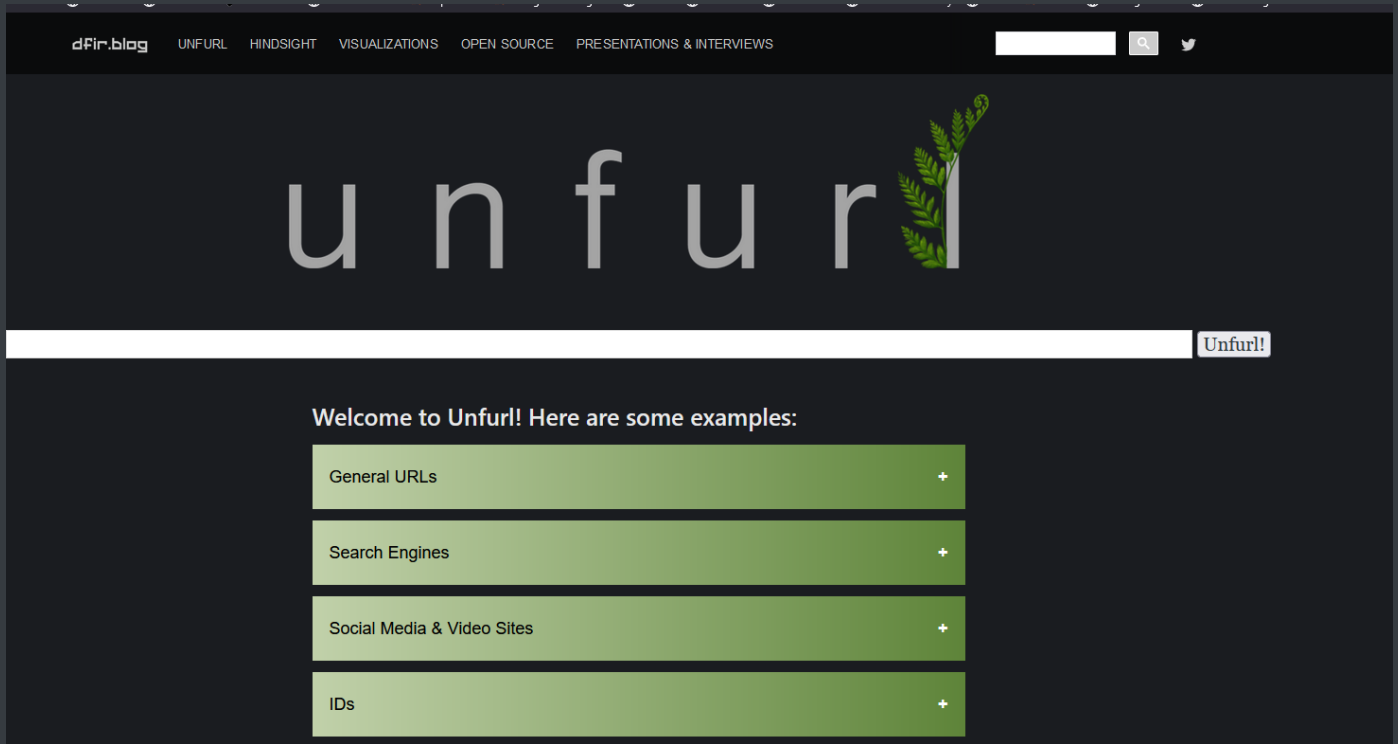
How to Compress and Extract Files Using the tar ...

16-Aug-2023 — Run "**tar** -czvf (archive name).**tar.gz** (pathtofile)" in the Terminal to **compress** a file or **folder**. To extract an archive to the current **folder**, ...

Compress an Entire Directory... • Exclude Directories and Files

So far we dont know what to make of these urls. Just from context we know that the discord attachment and this google search url are connected because we saw some archive instructions using tar in the pdf file, and it looks like karen had some problems doing that so she used google for help.

Before diving into the questions answers, if we take a quick look at questions they demand answers like timestamps and other information which all look overwhelming because we only have 2 urls as artifacts and nothing more. Well here comes the learning curve for this sherlock. We will utilise a tool called unfurl which gives forensically important information and parses out so much information just from a single URL!!!!!!.

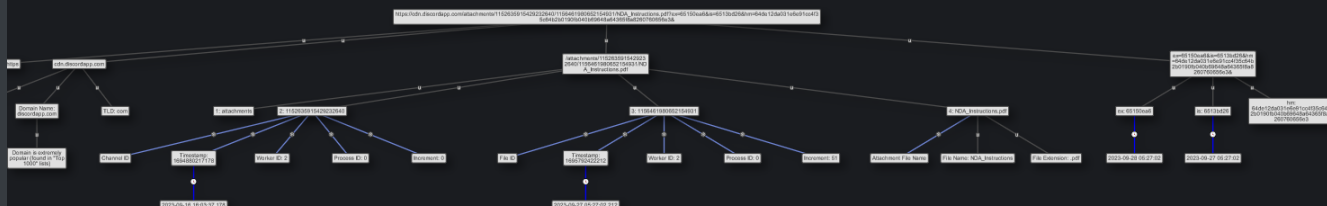


Questions and Answers :

Q1 When did the suspect first started Direct Message (DM) conversation with the external entity (A possible threat actor group which targets organizations by paying employees to leak sensitive data)? Please answer in UTC time

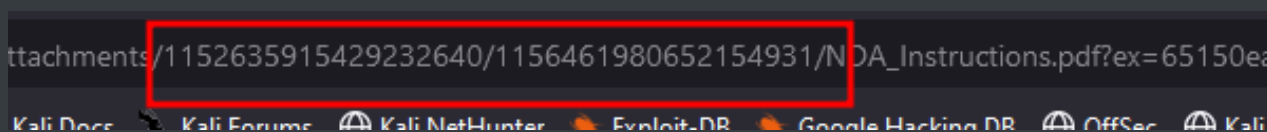
So we need a timestamp in utc of when the threat actors reached out to karen via DM. All we have is a download url for an attachment but as you will see now how we can get so much more than that just from a url. Enter the 1st url in unfurl and let the magic start.

931/NDA_Instructions.pdf?ex=65150ea6&is=6513bd26&hm=64de12da031e6e91cc4f35c64b2b0190fbo40b69648a64365f8a8260760656e3& Unfurl!!



We see a lot of data in the constellation(Graph) below.

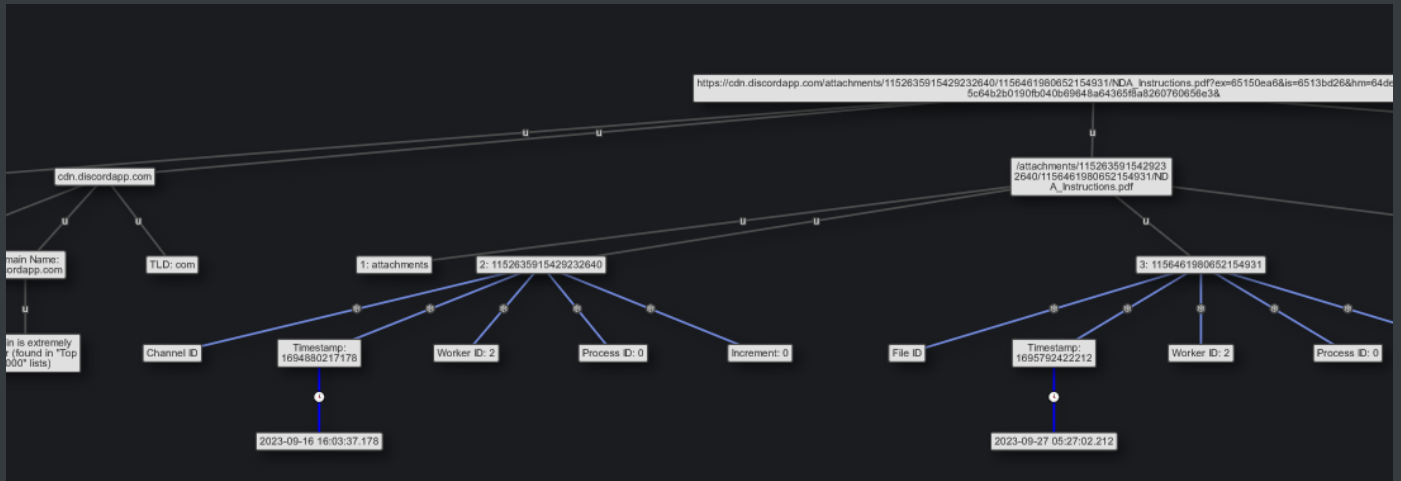
Before diving in let me explain a little bit. Discord urls contain several randomised numbers like this



these are referred as snowflakes and its a datastoring kind of thing. In context of discord

"A Snowflake is a **unique ID for a resource which contains a timestamp.**"

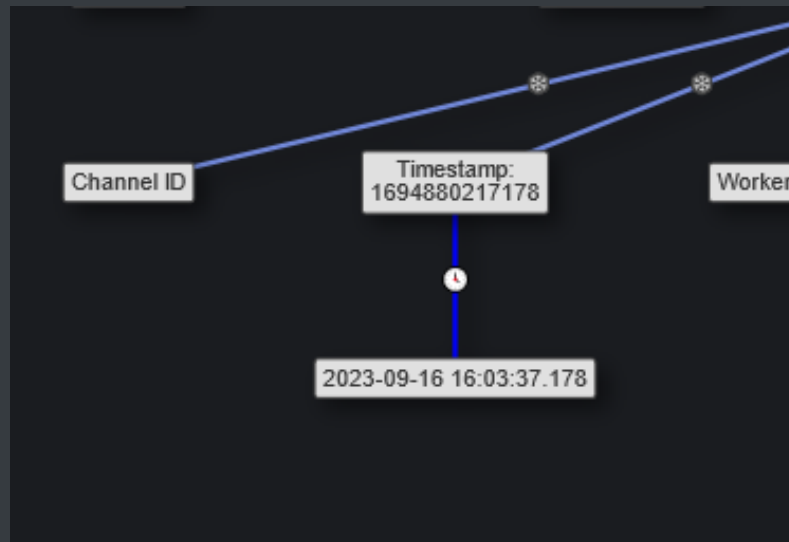
In reality these are channel UUIDs, dm UUID etc. These IDs are formed using different entities including timestamps when the specific server or DM was created(2 users first started conversation), when a specific channel was created in a server and so on. These all are very helpful in cases including discord as this provides more context.



If we take a closer look we can see how each component of the url is broken down and eventually displayed as an entity. For this question we want a timestamp when the DM conversation was first started between suspect and the threat actor.



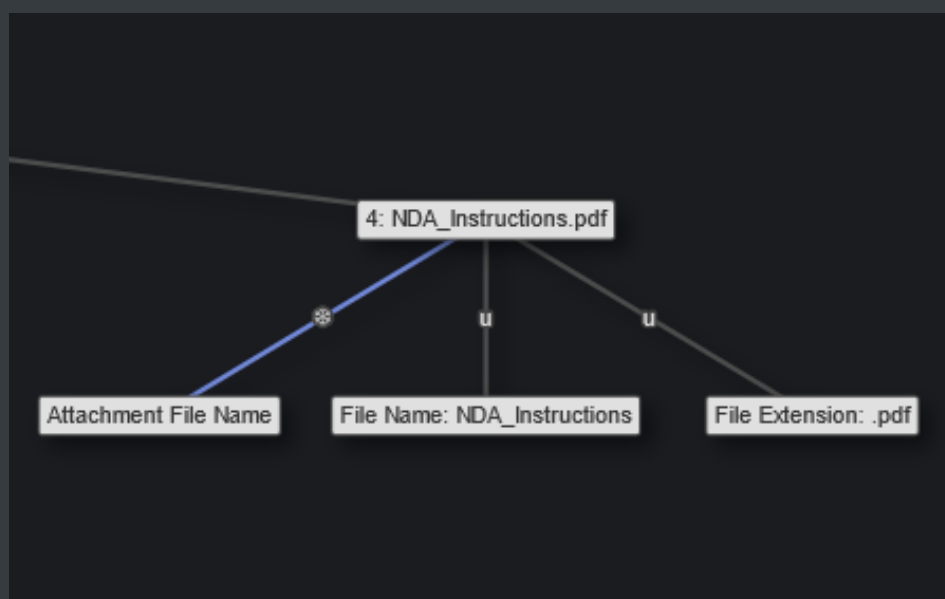
We know the information in the above image because of how snowflakes are architected and also because of extensive testing I did. The first timestamp in the graph is from the top of hierarchy meaning when that specific chat space (DM) was started/created. The first timestamp shares a Channel ID entity suggesting this is when the DM/CHAT was first created.



Ans 2023-09-16 16:03:37

Q2 What was the name of the file sent to the suspected insider threat?

We already downloaded the attachment so we know the name of the file. We also get the same information from unfurl.



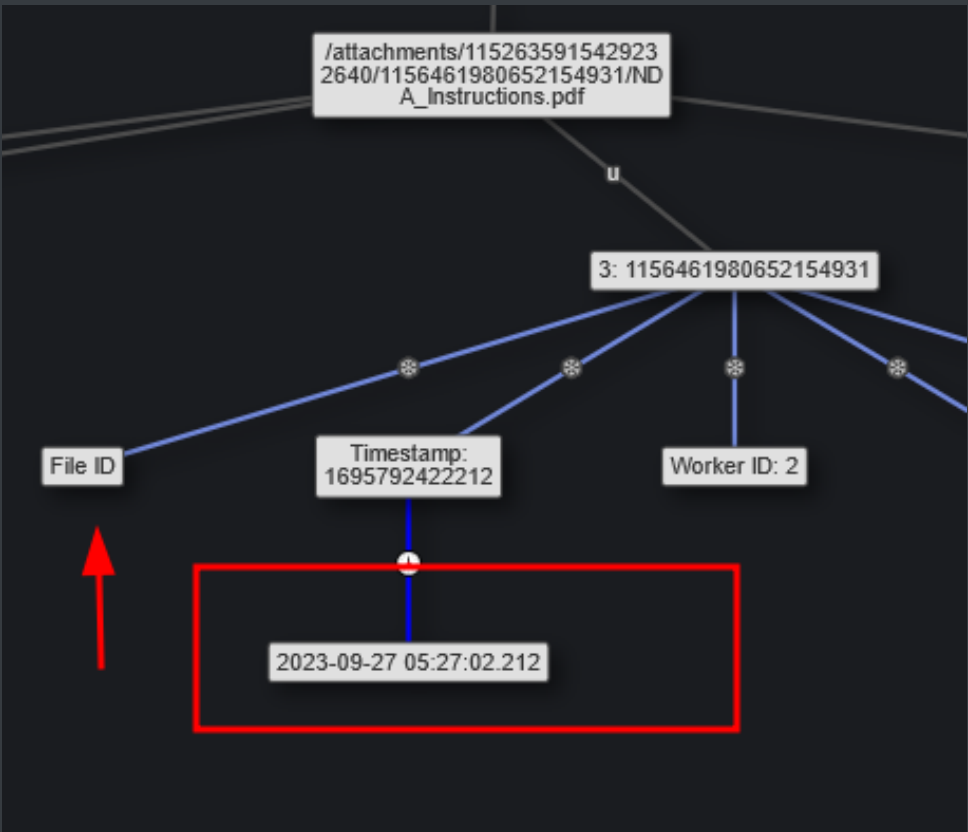
Ans NDA_Instrucstions.pdf

Q3 When was the file sent to the suspected insider threat? Please answer in UTC

Now we want to find when was the pdf sent to the employee. We will look under the same component in our unfurl graph.



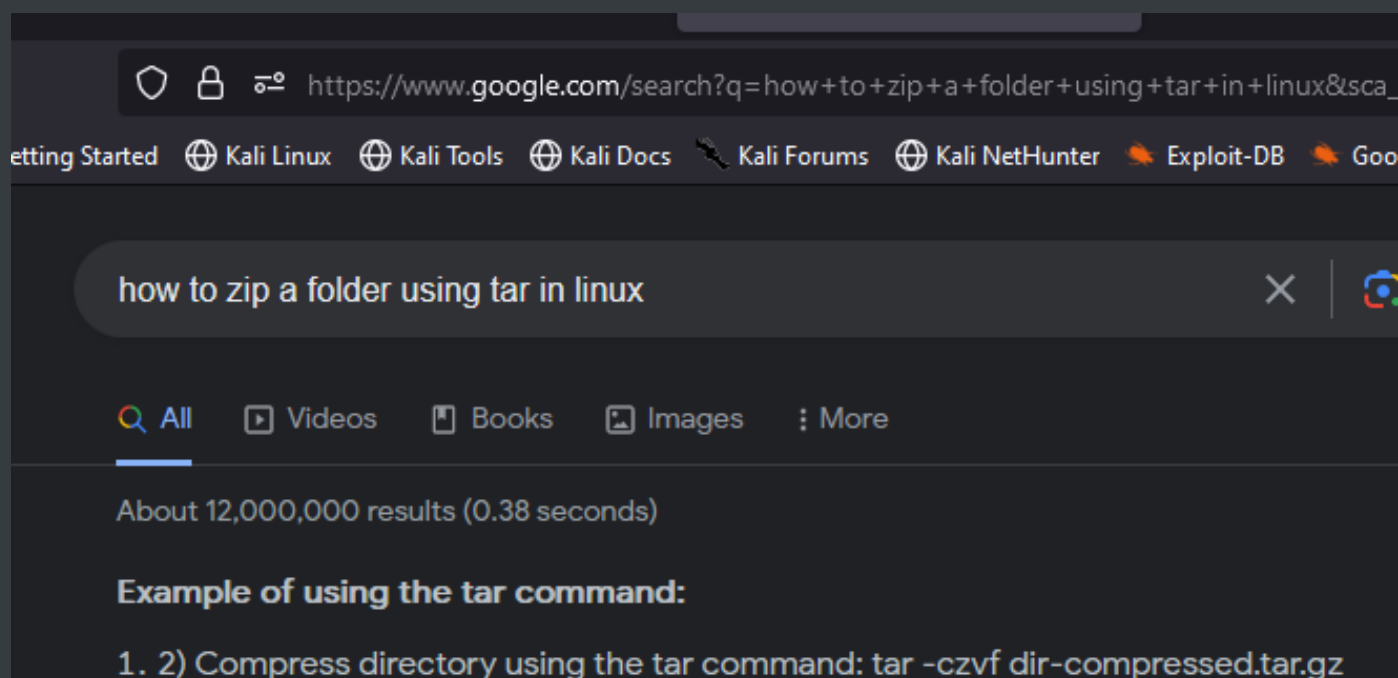
Now how do we know this is the timestamp when the file was sent?. The second timestamp also shares an FILE ID entity which suggests this is the time when the pdf was delivered.



Ans 2023-09-27 05:27:02

Q4 The suspect used google to search something after receiving the file. What was the search query ?

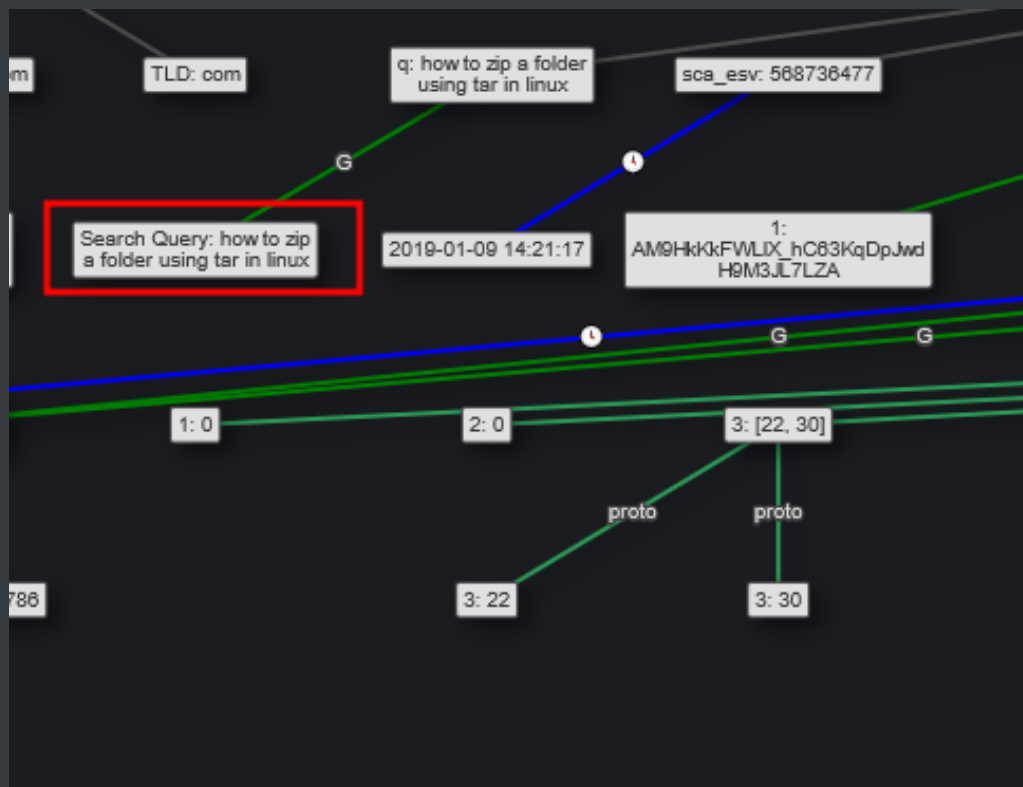
Now lets move on to the second IOC. Slap in the url in unfurl. We didnt need to use unfurl for answering this because as we already did previously enter the url in search bar we get the results.



But still lets use unfurl to find the answer too. First of all the graph is a mess in this url



But lets focus and try to find relevent entity.

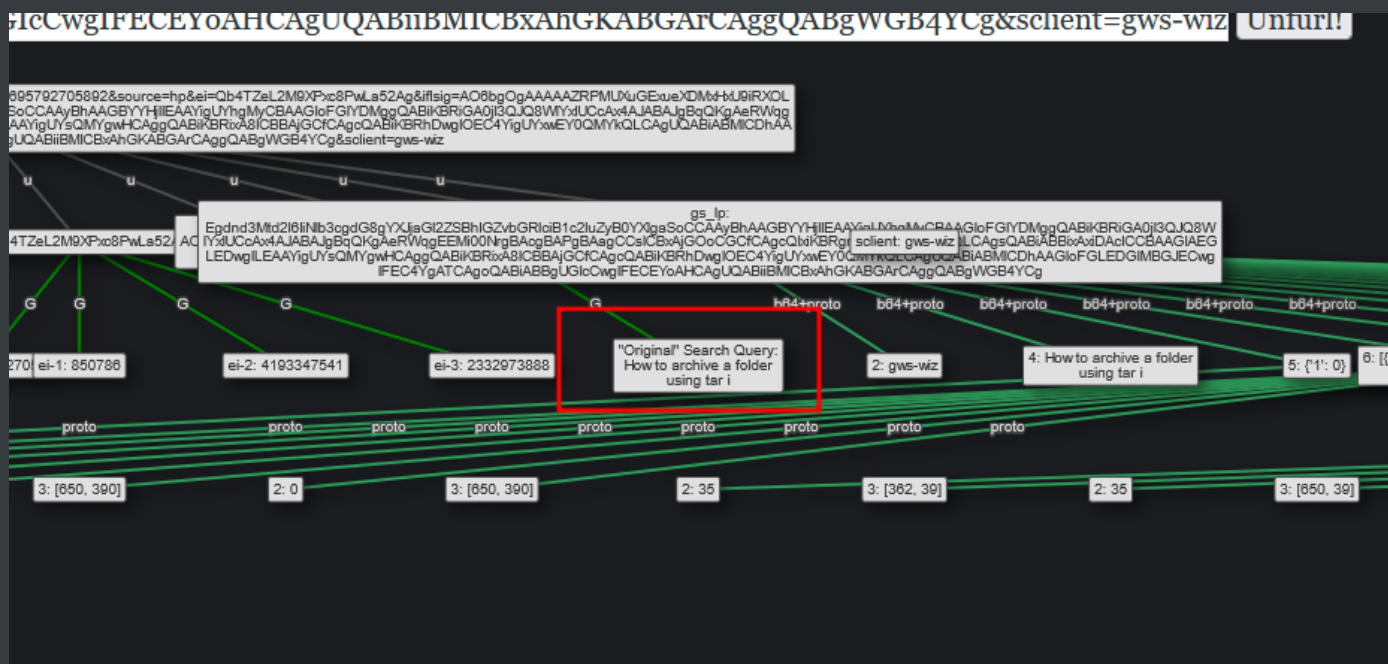


Here we find our search query.

Ans how to zip a folder using tar in linux

Q5 The suspect originally typed something else in search tab, but found a google search result suggestion which they clicked. Can you find out what words were written in search bar by the suspect originally?

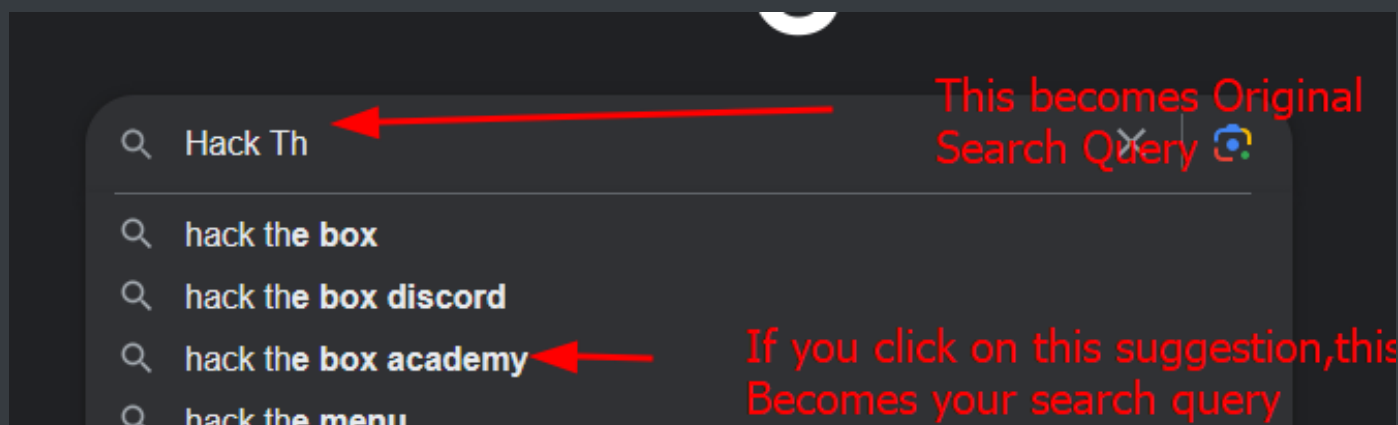
Now we will see the true power of unfurl and the amount of information residing in urls which we use on a daily basis.



We see an entity named Original Search query which is expanded from a blob of encoded data from the url. Phew, now we know why google search urls are so gigantic.

So you might be thinking, what is this Original search query. Well when you type something in google search and suggestions pop up and you click on any one of them. The original search query in this case becomes the text which you had typed in the search box, it doesn't matter that it is partial or doesn't make sense that's the original search query. And the suggestion which you clicked becomes your Search query.

Let me show you an example.

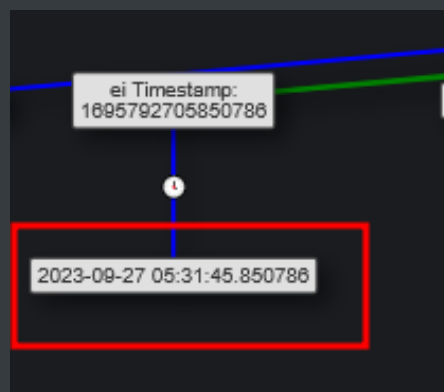


So now we know that the employee originally typed "How to archive a folder using tar i" and at this point in time a suggestion popped up which we know from Question 4 answer "how to zip a folder using tar in linux" and user clicked that suggestion.

Ans How to archive a folder using tar i

Q6 When was this google search made? Please answer in UTC

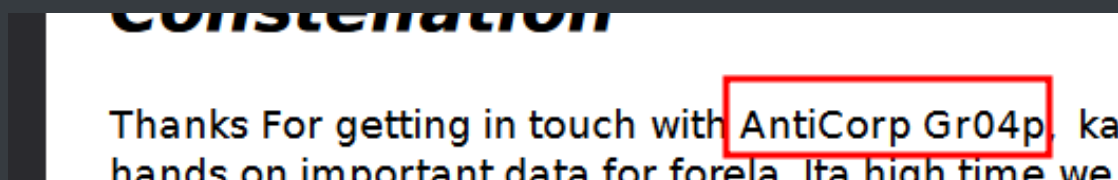
As explained before, the first timestamp would be the time when this whole query was generated/searched.



Ans 2023-09-27 05:31:45

Q7 What is the name of the Hacker group responsible for bribing the insider threat?

We know this information from the pdf file.



Ans AntiCorp Gr04p

Q8 What is the name of suspected Insider threat ?

This can also be found from pdf

Ans Karen Riley

Q9 What is the anomalous stated creation date of the file sent to the insider threat? (UTC)

Lets review the metadata for the pdf file to answer this. We can look at the file properties in a PDF vewier, or use the linux command line tool 'pdftinfo' to see this:

```
pdftinfo NDA_Instructions.pdf
```

```
$pdftinfo NDA_Instructions.pdf xs/Constellation/Artifacts/NDA_Instructions.pdf
Title: ct: F KarenForela_Instructions (Stop destroying env)
Subject: C Forela_Mining stats and data campaign (Stop destroying env)
Keywords: None
Author: en: A CyberJunkie@AntiCorp.Gr04p
Creator: A AntiCorp
Producer: S AntiCorp PDF FW
CreationDate: S Sat Jan 17 21:45:22 2054 UTC
ModDate: F Sat Jan 17 21:45:22 2054 UTC
Custom Metadata: no
Metadata Stream: no
Tagged: y: no
UserProperties: A no portrait (210 x 297 mm)
Suspects: no
Form: none
JavaScript: no
Pages: 1
Encrypted: no
Page size: 595.276 x 841.89 pts (A4)
Page rot: 0
File size: 25995 bytes
Optimized: no
PDF version: 1.7
```

If we read the pdf subject line it reads "Forela_Mining stats and data campaign (Stop destroying env)"

This looks like this is either an APT or an activist group . APT dont usually reveal their names openly so Activist hacking groups makes more sense.

We see authors email address "CyberJunkie@AntiCorp.Gr04p"

We see the creation date which is obviously to confuse analysts and hide their tracks

Ans 2054-01-17 21:45:22

Q10 Forela threat intel team are working on uncovering this incident. Any OpSec mistake made by the attackers are crucial for forela's security team. Try to help the threat intel team and find the real name of the agent/handler from anticorp .

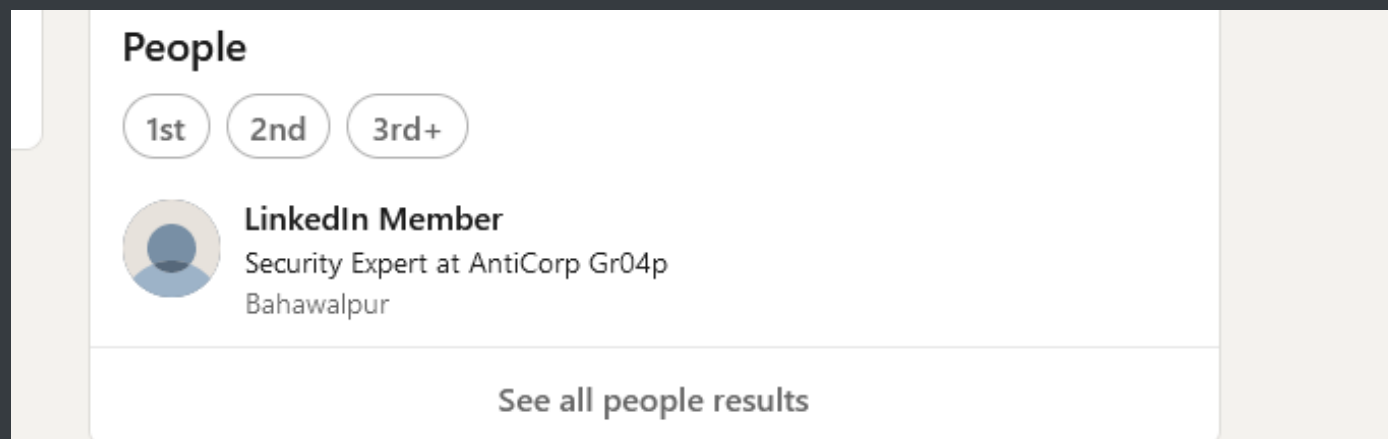
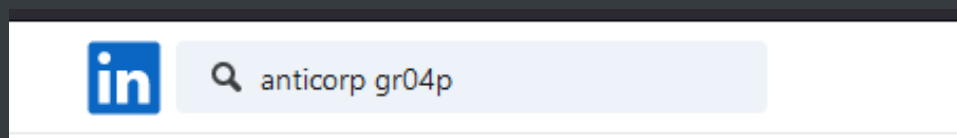
To answer this question we need to put on our OSINT hat. Lets try to think of information we know so far

An activist threat group named AntiCorp Gr04p.

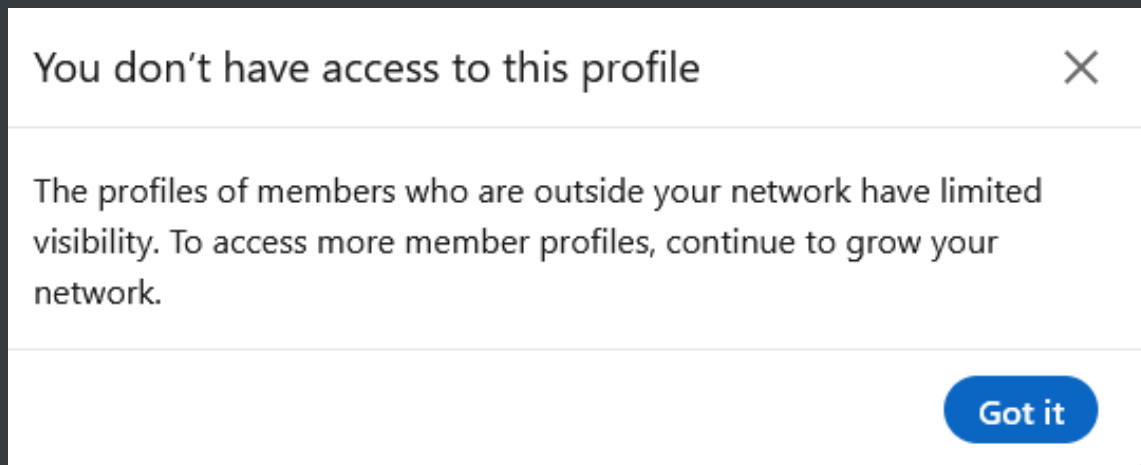
An affiliated Email address with the threat actor "CyberJunkie@AntiCorp.Gr04p"

Lets go on linkdn to start our hunt

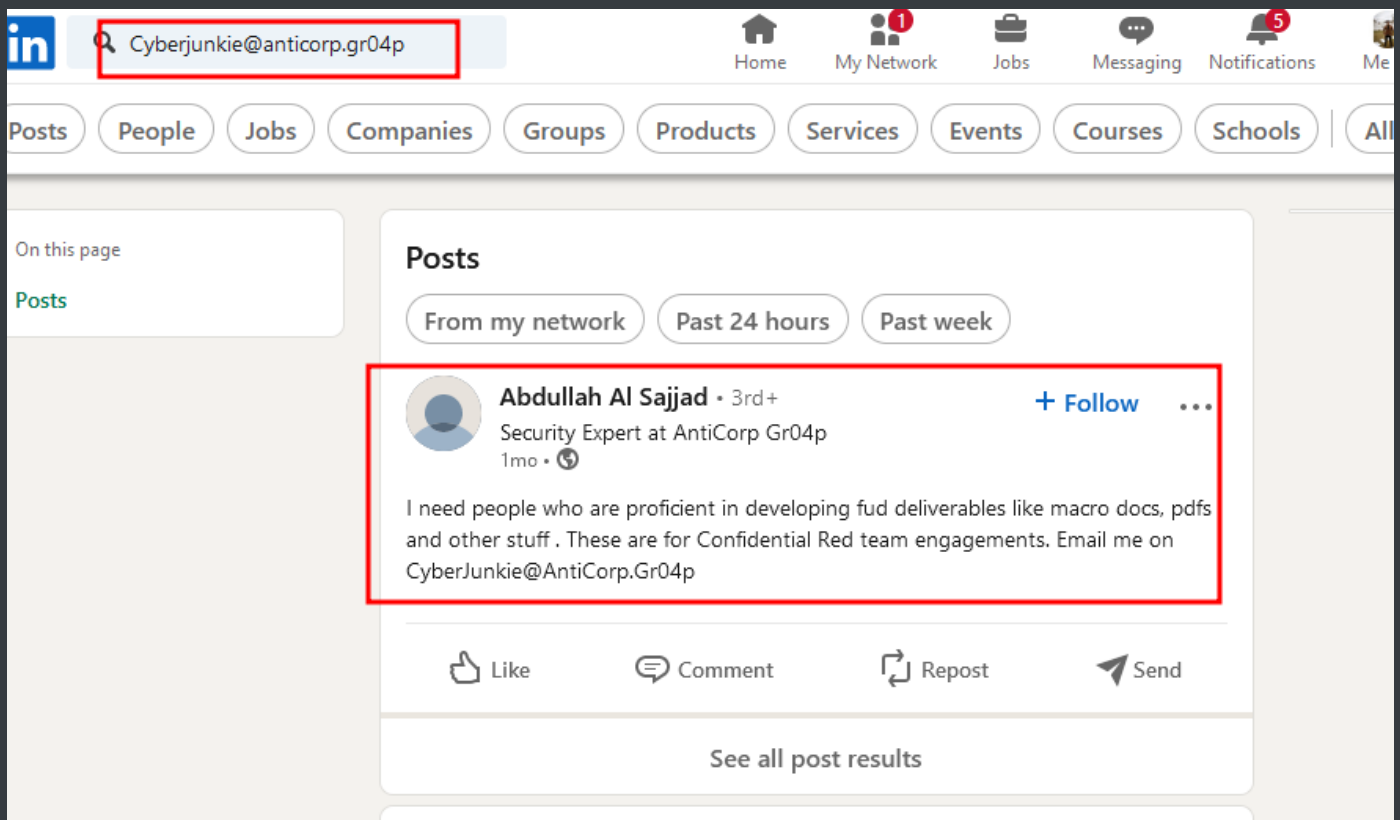
We search for



We see this member . But we cant open this account because this member has limited visibility enabled on linkdn



Don't worry we have yet another piece of information. We will now search the threat actors "Email address" as a keyword to try our luck



Looks like we hit a jackpot. We couldnt navigate and skim through this actors lindkdn profile but we can see the public posts from this account. Weirdly, if we now try to navigate this users profile we can. This probably means they have hidden their profile to be discovered via the linkedin search. We found this from one of their posts

They are acting as an security expert and trying to hire more people. This strategy is not uncommon as IRAN APTs run their entire operations through affiliates program and they also hire on linkedn appearing to be legitimate.

Ans Abdullah Al Sajjad

Q11 To Which City does the threat actor belongs to?

We can see this information by going to their profile



Ans Bahawalpur